

BỔ SUNG: Admin Quản Lý Roles (Python + Flask)

BỐI CẢNH

API #15 (GET /roles) — Public, chỉ đọc. API #57 (POST /admin/users/:id/roles) — Gán role cho user. Còn thiếu: Admin tạo / sửa / xóa role, và Thu hồi role khỏi user.

DB schema:

```
roles:      role_id, role_code(UNIQUE), role_name, description,
            is_system_role(BIT, def=1), status(ACTIVE|SUSPENDED)
user_roles: user_role_id, user_id, role_id, status(ACTIVE|REVOKED),
            assigned_by_user_id, assigned_at, revoked_at
```

Quy tắc cứng:

- `is_system_role=1` (CUSTOMER, SELLER, ADMIN, SHIPPER) → KHÔNG được sửa/xóa
- Custom role đang có user ACTIVE → KHÔNG được xóa cho đến khi thu hồi hết

API A • Create Role `POST /api/v1/admin/roles` | Admin only

Body: `{role_code, role_name, description?}`

```
python
```

```

@admin_bp.route('/admin/roles', methods=['POST'])
@require_role('ADMIN')
def create_role():
    data = request.get_json()
    role_code = data.get('role_code', '').strip().upper()
    role_name = data.get('role_name', '').strip()
    description = data.get('description', '').strip() or None

    # Validate
    if not role_code or not role_name:
        return jsonify({'success': False, 'message': 'role_code và role_name là'})

    import re
    if not re.match(r'^[A-Z][A-Z0-9_]{1,29}$', role_code):
        return jsonify({
            'success': False,
            'message': 'role_code chỉ gồm chữ hoa, số, dấu gạch dưới, tối đa 30
        }), 400

    conn = get_db_connection()
    cursor = conn.cursor()

    # Check trùng role_code
    cursor.execute("SELECT 1 FROM roles WHERE role_code=?", (role_code,))
    if cursor.fetchone():
        return jsonify({'success': False, 'message': f'role_code "{role_code}"

    cursor.execute("""
        INSERT INTO roles (role_code, role_name, description, is_system_role, s
        OUTPUT INSERTED.role_id, INSERTED.role_code, INSERTED.role_name,
            INSERTED.description, INSERTED.status, INSERTED.created_at
        VALUES (?, ?, ?, 0, 'ACTIVE')
    """, (role_code, role_name, description))

    row = cursor.fetchone()
    conn.commit()

    return jsonify({
        'success': True,
        'data': {
            'role_id': row[0],
            'role_code': row[1],
            'role_name': row[2],

```

```
        'description': row[3],
        'status':      row[4],
        'created_at':  str(row[5])
    },
    'message': 'Tạo role thành công'
}), 201
```

→ **201** role object → **400** thiếu field hoặc role_code sai format → **409** role_code đã tồn tại

API B • Update Role `PATCH /api/v1/admin/roles/:id` | Admin only

Body (partial): `{role_name?, description?, status?(ACTIVE|SUSPENDED)}`

python

```

@admin_bp.route('/admin/roles/<int:role_id>', methods=['PATCH'])
@require_role('ADMIN')
def update_role(role_id):
    conn = get_db_connection()
    cursor = conn.cursor()

    # Lấy role hiện tại
    cursor.execute("""
        SELECT role_id, role_code, is_system_role, status
        FROM roles WHERE role_id=?
    """, (role_id,))
    role = cursor.fetchone()

    if not role:
        return jsonify({'success': False, 'message': 'Role không tồn tại'}), 404

    if role[2] == 1: # is_system_role
        return jsonify({
            'success': False,
            'message': f'Không thể sửa role hệ thống "{role[1]}"'
        }), 403

    data = request.get_json()
    if not data:
        return jsonify({'success': False, 'message': 'Không có dữ liệu cập nhật'})

    # Chỉ update field được gửi
    allowed = {'role_name', 'description', 'status'}
    updates = {k: v for k, v in data.items() if k in allowed}

    if not updates:
        return jsonify({'success': False, 'message': 'Không có field hợp lệ để update'})

    if 'status' in updates and updates['status'] not in ('ACTIVE', 'SUSPENDED'):
        return jsonify({'success': False, 'message': 'status chỉ nhận ACTIVE hoặc SUSPENDED'})

    set_clause = ', '.join(f"{k}=?" for k in updates)
    values = list(updates.values()) + [role_id]

    cursor.execute(f"""
        UPDATE roles
        SET {set_clause}, updated_at=SYSUTCDATETIME()
        OUTPUT INSERTED.role_id, INSERTED.role_code, INSERTED.role_name,
    """)

```

```

        INSERTED.description, INSERTED.status, INSERTED.updated_at
    WHERE role_id=?
    """ , values)

    row = cursor.fetchone()
    conn.commit()

    return jsonify({
        'success': True,
        'data': {
            'role_id': row[0],
            'role_code': row[1],
            'role_name': row[2],
            'description': row[3],
            'status': row[4],
            'updated_at': str(row[5])
        }
    }), 200

```

→ **200** role object đã update → **400** không có field hợp lệ | status sai → **403** cố sửa system role
 → **404** role không tồn tại

API C • Delete Role `DELETE /api/v1/admin/roles/:id` | Admin only

Soft delete: `status='SUSPENDED'`. Từ chối nếu còn user đang dùng.

python

```

@admin_bp.route('/admin/roles/<int:role_id>', methods=['DELETE'])
@require_role('ADMIN')
def delete_role(role_id):
    conn = get_db_connection()
    cursor = conn.cursor()

    # Lấy role
    cursor.execute("""
        SELECT role_id, role_code, is_system_role, status
        FROM roles WHERE role_id=?
    """, (role_id,))
    role = cursor.fetchone()

    if not role:
        return jsonify({'success': False, 'message': 'Role không tồn tại'}), 404

    if role[2] == 1: # is_system_role
        return jsonify({
            'success': False,
            'message': f'Không thể xóa role hệ thống "{role[1]}"'
        }), 403

    if role[3] == 'SUSPENDED':
        return jsonify({'success': False, 'message': 'Role đã bị vô hiệu hóa trước'})

    # Kiểm tra còn user đang dùng role này không
    cursor.execute("""
        SELECT COUNT(*) FROM user_roles
        WHERE role_id=? AND status='ACTIVE'
    """, (role_id,))
    active_count = cursor.fetchone()[0]

    if active_count > 0:
        return jsonify({
            'success': False,
            'message': f'Không thể xóa: còn {active_count} user đang có role này'
            f'Thu hồi role khỏi tất cả user trước.'
        }), 409

    # Soft delete
    cursor.execute("""
        UPDATE roles
        SET status='SUSPENDED', updated_at=SYSUTCDATETIME()
    """)

```

```
        WHERE role_id=?
        """ , (role_id,))
    conn.commit()

    return jsonify({
        'success': True,
        'message': f'Đã vô hiệu hóa role "{role[1]}"'
    }), 200
```

→ **200** {message: "Đã vô hiệu hóa role ..."} → **400** role đã SUSPENDED rồi → **403** cố xóa system role → **404** không tồn tại → **409** còn user đang dùng (kèm số lượng)

API D • Revoke Role khỏi User `DELETE /api/v1/admin/users/:id/roles/:role_id` | Admin only

Bổ sung cặp với API #57 (Assign Role). Thu hồi role đã gán.

```
python
```

```

@admin_bp.route('/admin/users/<int:user_id>/roles/<int:role_id>', methods=['DEL
@require_role('ADMIN')
def revoke_role(user_id, role_id):
    admin_id = request.user['user_id']
    conn = get_db_connection()
    cursor = conn.cursor()

    # Kiểm tra user tồn tại
    cursor.execute("SELECT 1 FROM users WHERE user_id=? AND deleted_at IS NULL"
    if not cursor.fetchone():
        return jsonify({'success': False, 'message': 'User không tồn tại'}), 40

    # Kiểm tra assignment đang ACTIVE
    cursor.execute("""
        SELECT ur.user_role_id, r.role_code, r.is_system_role
        FROM user_roles ur
        JOIN roles r ON ur.role_id=r.role_id
        WHERE ur.user_id=? AND ur.role_id=? AND ur.status='ACTIVE'
    """, (user_id, role_id))
    assignment = cursor.fetchone()

    if not assignment:
        return jsonify({'success': False, 'message': 'User không có role này'})

    # Không thu hồi role CUSTOMER khỏi chính mình (tránh tự khóa)
    if assignment[1] == 'ADMIN' and user_id == admin_id:
        return jsonify({
            'success': False,
            'message': 'Không thể tự thu hồi quyền Admin của chính mình'
        }), 403

    cursor.execute("""
        UPDATE user_roles
        SET status='REVOKED', revoked_at=SYSUTCDATETIME(), updated_at=SYSUTCDAT
        WHERE user_role_id=?
    """, (assignment[0],))
    conn.commit()

    return jsonify({
        'success': True,
        'message': f'Đã thu hồi role "{assignment[1]}" khỏi user'
    }), 200

```


→ **200** {message: "Đã thu hồi role ..."} → **403** cố tự thu hồi ADMIN của mình → **404** user không tồn tại | user không có role này

CHECKLIST

- ☐ 4 route đăng ký đúng trong Blueprint admin
- ☐ Auth: @require_role('ADMIN') cho cả 4 API
- ☐ is_system_role=1 → block sửa/xóa (API B, C)
- ☐ API C: kiểm tra active_count trước khi xóa
- ☐ API D: block tự thu hồi ADMIN của chính mình
- ☐ role_code format validation: ^[A-Z][A-Z0-9_]{1,29}\$
- ☐ OUTPUT INSERTED.* để lấy lại row sau INSERT/UPDATE (SQL Server syntax)